Web

Author: fb0sh

基础：

Docker

一定要学容器

Web开发

PHP
变量 (类型，定义和使用)， 输入输出
字符串， 常量， 数组， 全局变量， 函数
比较，逻辑控制 if 循环 foreach， while, switch
魔术常量，命名空间，面向对象，序列化和反序列化
文档版： https://w3schools.tech/zh-cn/tutorial/php/index
视频版： https://www.bilibili.com/video/BV1fa11YmETd/
HTML, CSS, JS/NodeJS
视频版： https://www.bilibili.com/video/BV1BT4y1W7Aw/
文档版： https://www.runoob.com/
MIME
https://developer.mozilla.org/zh-CN/docs/Web/HTTP/Guides/MIME_types/Common_types

脚本语言

Python
变量（数字， 字符串， 列表， 字典， 元组，集合， 特殊变量）
流程控制（条件控制， 循环）
函数（匿名函数， 装饰器）
库（导入， 模块， 文件读写， OS库， **requests网络库**， 正则）
Python
文档版： https://www.runoob.com/python/python-tutorial.html
视频版： https://www.bilibili.com/video/av52080698
requests https://www.bilibili.com/video/BV1zf4y1x79k **视频版**
Java
同上类似（自己找吧）

数据库

SQL基础和概念 CRUD
https://www.bilibili.com/video/BV1yw4m1S7Be/

渗透相关：（搜索关键词自行学习）

权限相关：

权限绕过、越权漏洞 Cookie绕过， URL参数修改
JWT https://portswigger.net/web-security/jwt
默认凭证登录（如 `admin:admin`） https://blog.csdn.net/SPOTO2021/article/details/135369923

信息泄露：

服务器指纹： whatweb， wappalyzr
源码泄漏 备份文件，.git
敏感数据泄露日志敏感信息泄露、攻击痕迹隐藏
如 nginx apache lighttpd MySQL ... /var/log/auth.log
信息泄露、默认配置漏洞
目录遍历（如 `/var/www/html/../../etc/passwd`）。
暴露的调试接口（如 `/phpinfo.php` 或 `/actuator/health`）。
进行目录枚举

WEB：

SQL注入 https://www.bilibili.com/video/BV1c34y1h7So （sqlmap）(https://portswigger.net/web-security)
HTTP头部注入（SQL注入） https://blog.csdn.net/weixin_54055099/article/details/126867632
命令注入 https://www.cnblogs.com/Satoris/articles/16662216.html （commix）
https://www.bilibili.com/video/BV1tG4y1c7Vb
SSTI https://www.bilibili.com/video/BV1tj411u7Bx （fenjing， sstimap）
SSRF漏洞 https://www.bilibili.com/video/BV1iQ4y1u7Pt/
XXE（XML外部实体注入）：解析恶意XML导致文件读取或RCE。
CSRF（跨站请求伪造）：诱骗用户执行非预期操作。
XSS https://www.bilibili.com/video/BV1vQ2WYEEhV/
前端JS逆向
逻辑漏洞 （登录验证等）
文件上传 https://www.bilibili.com/video/BV1JG411Z7jN/
PHP 反序列化 https://www.bilibili.com/video/BV1TH4y1U7tJ/
第三方库漏洞、CVE利用 vulhub
https://github.com/vulhub/vulhub

中间件 Tomcat Nginx
常见CMS
PHP： WordPress Joomla Drupal Thinkphp Laravel
Java：JBoss Spring Jenkins
Python：Flask Django

/proc/ pearcmd

核心：信息收集+Fuzz

学习路线

docker的学习要 贯穿始终

1. PHP + HTML/JS/CSS， 数据库+SQL注入，命令执行，文件上传 （1 个月?
2. Python + SSTI, SSRF, CSRF, XSS, XXE , 了解常见PHP CMS （ 也是1个月
3. Java + java和python的 常见cms， PHP反序列化 ，了解tomcat, nginx（2个月?
4. JWT+ vulhub